

STEM BIO-AI Evidence-Surface Scan v1.8.4

Repository: doctolib-lab/doctobert | **Commit:** 90a8bbe7260d | **Branch:** main
Audit Date: 2026-06-24 | **Mode:** LOCAL_ANALYSIS | **Policy:** default (mirror_only)

32 / 100

Final Score

T0 Rejected

Use Scope:

Do not rely on this repository without independent expert validation.

■ **About this score**

Score reflects calculation integrity, not calibrated validity. Triage signal only.

- **What is verified:** calculation integrity. The same input produces the same score.
- **What is not verified:** calibrated measurement validity. Weights and detector scope remain bounded.
- **Use this score as a triage signal:** not as certification, safety proof, or deployment approval.

Stage 1
README Evidence

60 / 100

Stage 2R
Repo-Local Consistency

40 / 100

Stage 3
Code / Bio Responsibility

0 / 100

Stage 4
Replication Evidence

50 / 100

What Is Actually Present

- Some reproducibility evidence exists, including environment lock or container surfaces.
- Regulatory traceability mappings exist for reproducibility and record-keeping scaffolding.
- No strong positive local evidence detected by the CLI scan.

Governance Posture

T0 Rejected — Do not rely on this repository without independent expert validation.
Bio-governance posture is partial and bounded. Some provenance and replication signals exist, but explicit non-clinical boundary and trust-control evidence remain insufficient.

What Is Missing Or Contradicted

- Clinical-adjacent surfaces exist without an explicit non-diagnostic/non-clinical boundary.

Regulatory Traceability

- **Frameworks touched:** EU AI Act, ICH M15, IMDRF, FDA
- **Structural alignment exists (3):** ICH M15 §2.1.2 — Context of Use; EU AI Act Art. 12 — Record Keeping; ICH M15 §4.3 — Code & Data Submission
- **Signal-only references (1):** useful for pre-audit traceability, but not strong enough to count as compliance proof
- **Meaning:** repository evidence maps to governance frameworks, but the report does not establish compliance or clearance.
- **Why this matters:** this section helps answer whether governance scaffolding is present at all before a formal audit, not whether the repository is approved for use.

AIRI Risk Triggers

- **Secondary risk vocabulary:** 2 mapped triggers across 32 in-bundle AIRI risks.
- **Meaning:** broadens local findings into risk language; it does not prove harm, safety, or compliance.
- **Why this matters:** useful when a user needs a broader risk vocabulary around governance gaps, not when they need deployment approval.
- **Mapped theme 1:** 24.01.03 Safe exploration problem with widely deployed... | primary: C5_compliance_boundary_integrity | why: C5_compliance_boundary_integrity: Clinical-adjacent surfaces exist without an explicit...
- **Mapped theme 2:** 69.01.00 False information | primary: C5_compliance_boundary_integrity | why: C5_compliance_boundary_integrity: Clinical-adjacent surfaces exist without an explicit...
- **Still unmapped here:** 65.03.03 Reidentification; 70.02.02 Misinformation —...; 39.25.00 Verifiability —...

Chapter 1 — Stage Scorecard and Governance Scoring

Stage 1 — README Evidence Signal | Weight: 0.40

60 / 100 S1 Score	Check	Points	Evidence / Finding
	Baseline	+60	Non-nascent README evidence baseline.
	BIO/medical terms in README	+10	README exposes bio/medical domain vocabulary.
	R2: Regulatory Framework	-5	CA-INDIRECT surface lacks regulatory or governance framework language. [partial-credit ladder: +15 strong framework +5 weak self-asserted compliance -5 CA-INDIRECT...
	R3: Clinical Boundary	-5	CA-INDIRECT surface lacks explicit non-clinical or non-diagnostic boundary.
• Clinical-Adjacent: YES (CA-INDIRECT) • Explicit Disclaimer: ABSENT • T0 Hard Floor: Clear			

Stage 2R — Repo-Local Consistency | Weight: 0.20

40 / 100 S2R Score	Check	Points	Evidence / Finding
	Baseline	+60	Non-nascent local repository baseline. — Every repository that is not nascent starts at 60. This baseline accounts for basic structural maturity. —...
	R2R-D2: Missing Clinical Boundary (PENALTY)	-20	Clinical-adjacent surfaces exist without an explicit non-diagnostic/non-clinical boundary. — Clinical-adjacent repository lacks an explicit 'research use only' or 'not for...
• Consistency Verdict: Local Contradiction / Insufficient Consistency			

Stage 3 — Code & Bio Responsibility | Weight: 0.40

0 / 100

S3 Score

Engineering Accountability (T-series)

Check	Points	Evidence / Finding
T1: CI/CD Workflow	0 / 15	No workflow files detected. — CI/CD workflows (GitHub Actions, GitLab CI, CircleCI) verify that commits do not silently break the pipeline. Full credit (15) requires...
T2: Domain-Specific Tests	0 / 15	No tests detected. — Domain-specific tests verify biological outputs — e.g., sequencing pipeline correctness, variant call validation, or genomic data integrity. Full credit...
T3: Changelog & Release Hygiene	0 / 15	No changelog detected. — A CHANGELOG tracks which version fixed which defect — essential for regulatory traceability and reproducibility audits. CHANGELOG.md, CHANGELOG, or...

Biological Integrity (B-series)

Check	Points	Evidence / Finding
B1: Data Provenance Controls	0 / 15	No dependency/provenance manifest detected. — Dependency manifests (requirements.txt, pyproject.toml, environment.yml) establish reproducibility context. Score 10 if...
B2: Bias / Limitations Documentation	0 / 15 [Manual review required]	No bias/limitations language detected by local CLI scan. — Documentation of algorithmic bias, limitations, or model boundary conditions. Score 8 for boundary language; max...
B3: COI & Funding Disclosure	0 / 5 [Manual review required]	No COI/funding disclosure detected by local CLI scan. — Conflict of interest and funding disclosure in README or FUNDING.md. Required for institutional review context and...

Normalized score: T-series 0/45 + B-series 0/35 = raw 0/80 → 0/100.

Stage 3 Gap Analysis — Path to Next Tier

Stage 3 gap interpretation

T-series vs B-series	T-series (engineering) attained: 0 / 45 B-series (bio integrity) attained: 0 / 35
Local CLI scan maximum	55 / 100 (T1+T2+T3 max 15 each; B1 max 10; B2/B3 require manual review)
Gap to T3	38 points needed across all stages to reach final score >= 70
Gap to T4	53 points needed across all stages to reach final score >= 85
B2 Bias/Limitations	Not detectable — requires manual audit of README, model card, or supplementary documentation for validation boundaries and algorithmic limitations
B3 COI/Funding	Not detectable — requires inspection of README or FUNDING.md for conflict of interest and funding source disclosure

Stage 4 — Replication Evidence Lane | Separate lane

50 / 100

S4 Score

Check	Points	Evidence / Finding
S4: Container / Runtime Environment	0 / 10	No evidence detected for S4_container_environment.
S4: Reproduce Target	0 / 10	No Makefile detected.
S4: Environment Lock Evidence	10 / 10	Environment, dependency, or lock manifest detected.
S4: Exact Dependency Pins / Hashes	10 / 10	Exact dependency pin or hash evidence detected.
S4: Reproducibility Section	0 / 10	README exists but no reproducibility or replication section heading was detected.
S4: Checksums / Integrity Files	0 / 10	No evidence detected for S4_checksum_files.
S4: Dataset / Data Source URL	10 / 10	Dataset URL or data source reference detected.
S4: Model Artifact URL / Checksum	10 / 10	Model artifact URL or checksum evidence detected.
S4: CITATION.cff	0 / 5	No evidence detected for S4_citation_cff.
S4: License / Use Restriction	0 / 0	No license/use restriction language detected.
S4: CLI Entrypoint	5 / 5	CLI entry point or argparse interface detected.
S4: Deterministic Seed Setting	5 / 5	Deterministic seed setting detected.
S4: Runnable Examples	0 / 5	No evidence detected for S4_runnable_examples.
stage_4_raw_total	50 / 100	Raw Stage 4 rubric total. Stage 4 is reported separately and does not alter final score.

Replication tier: R2. Stage 4 is reported separately and does not alter the formal score.

Formal Score Effect

Final Score: 32 / 100 (T0 Rejected)

Formal effect: Stage 4 does not raise or lower the formal repository score.

- This page exists to show reproducibility and operational evidence posture separately from the governance score.
- Stronger replication evidence improves trust in reproducibility posture, not the formal governance tier.

Chapter 2 — Code Integrity Deep Analysis

Check	Points	Evidence / Finding
C1: Hardcoded Credentials	PASS	No direct credential patterns detected by local CLI scan. Scan: Scans for AWS access keys (AKIA*), OpenAI keys (sk-*), GitHub tokens (ghp_*), and api_key = '...' patterns...
C2: Dependency Pinning	PASS	Dependency manifest appears pinned or not present. Scan: Checks whether requirements.txt / pyproject.toml / environment.yml use exact version pins (==, sha256 hash) or...
C3: Deprecated Patient Paths	PASS	No deprecated patient-adjacent metadata patterns detected. Scan: Scans deprecated/directories for patient metadata patterns: patient_id, patient_age, patient_sex...
C4: Fail-Open Exceptions	PASS	No executable fail-open exception handler detected. Scan: Detects fail-open exception patterns: 'except Exception: pass' or 'except: return True' in code — these silently...
C5: Compliance Boundary Integrity	WARN	Clinical-adjacent surfaces exist without an explicit non-diagnostic/non-clinical boundary. Scan: Detects unsupported legal/compliance claims or clinical-boundary...
C6: Mock Auth / Fail-Open Boundary	PASS	No mock-auth or fail-open local-boundary warning detected in reviewed sources. Scan: Detects mock-auth, auto-login, or no-auth local/self-host boundary patterns in README...

Remediation Guidance

[WARN] C5: Compliance Boundary Integrity:

→ Treat privacy, legal, or clinical-adjacent claims as governance obligations. If README or product text invokes HIPAA, compliance, or self-hosted clinical safety, surface supporting controls, operating boundaries, and deployment constraints explicitly.

Classification & Repository Analysis

Check	Points	Evidence / Finding
Clinical Adjacent	YES	Severity: CA-INDIRECT. Triggered by BIO/CLINICAL_OUTPUT term regex match across README, docs, and code.
T0 Hard Floor	Clear	No T0_HARD_FLOOR condition detected.
Explicit Disclaimer	ABSENT	Disclaimer pattern not found in README or docs. High impact on Stage 1 and Stage 2R scores.
Files Scanned	134	Total files indexed by recursive walk. Text files only for content analysis; binary files counted but not read.
Execution Mode	LOCAL_ANALYSIS	No LLM calls. No network access. No runtime execution. Deterministic regex + file-system scan only.

File Integrity (SHA-256)

File	SHA-256 Hash
README.md	9F328B414D09CE31A170ACDAEBFC9A2036031989D5643C0B4144281D43513CF8

Chapter 3 — Regulatory Traceability

Regulatory basis note

Aligned to current official source classes as of June 2026: EU AI Act (Regulation (EU) 2024/1689); FDA QMSR, FDA ML-MD Transparency (2024), FDA PCCP (2025); ICH M15 MIDD (Step 4, Jan 2026); IMDRF SaMD Clinical Eval (2017), IMDRF GMLP (2025).
This is a traceability aid, not a compliance or clearance determination.

Stage 1 — README Intent

EU AI Act Art. 13 — Transparency

Not detected

Clinical-adjacent repository language was observed, but positive claim-boundary or limitation scaffolding was not detected in README/package surfaces.
Not assessed: IFU completeness; deployer communication workflow

Stage 2R — Repo Consistency

IMDRF SaMD — Clinical Context Boundary

Signal only

Repository-local contradiction and boundary signals are relevant to clinical-context traceability, not clinical validation.
Triggered by: *R2R_D2_missing_clinical_use_boundary*
Not assessed: target-population performance; operational clinical workflow fit

ICH M15 §2.1.2 — Context of Use

Partially aligned

Missing clinical-use boundary directly maps to ICH M15 §2.1.2 Context of Use: 'a concise, clear, and explicit description of the role and scope of the model' is required. Post-hoc alignment.
Triggered by: *R2R_D2_missing_clinical_use_boundary*
Not assessed: formal CoU document; regulatory submission completeness

Stage 4 — Replication

EU AI Act Art. 12 — Record Keeping

Partially aligned

Reproducibility and trace manifests support record-keeping scaffolding, not operational logging completeness.
Triggered by: *S4_environment_lock_evidence*
Not assessed: deploy-time event logging; runtime event completeness

ICH M15 §4.3 — Code & Data Submission

Partially aligned

Reproducibility environment signals align with ICH M15 §4.3: 'all documents and files supporting submitted MIDD evidence, including data used in M&S analyses and relevant coding scripts, should be submitted or available for regulatory review.' Post-hoc alignment.
Triggered by: *S4_environment_lock_evidence*
Not assessed: coding script completeness; dataset submission; formal regulatory submission

Structural signals partially align with traceability scaffolding. This remains a pre-audit traceability aid, not a compliance determination.

Chapter 4 — Remediation Actions, AIRI Risk Triggers & Method Boundary

4.1 Decision Path

Developer-facing decision path	
Stage 2R score	40 / 100 — repo-local contradictions and missing trust boundaries are holding the report down.
Stage 3 score	0 / 100 — accountability and bio-governance evidence remain partial rather than mature.

4.2 Top Remediation Actions

Priority	What to fix first
P1	Clinical-adjacent surfaces exist without an explicit non-diagnostic/non-clinical boundary. Add a prominent 'Research Use Only — Not for Clinical or Diagnostic Use' disclaimer to README H1 or H2 section. Reference applicable...

4.3 AIRI Risk Triggers Summary

AIRI summary	
Coverage	Covered Risks: 2 / 32 Coverage Rate: 0.062 Bundle Scope: curated_medical_clinical_subset
Meaning	AIRI broadens local governance findings into a secondary risk vocabulary. It does not prove harm, compliance, or deployment readiness.
Mapped theme 1	24.01.03 Safe exploration problem with widely... primary: C5_compliance_boundary_integrity why: C5_compliance_boundary_integrity: Clinical-adjacent surfaces exist without an...
Mapped theme 2	69.01.00 False information primary: C5_compliance_boundary_integrity why: C5_compliance_boundary_integrity: Clinical-adjacent surfaces exist without an...
Known gaps	65.03.03 Reidentification, 70.02.02 Misinformation —..., 39.25.00 Verifiability —...
Why this matters	This section helps a reviewer describe governance weaknesses in broader risk language, but it should remain secondary to repository boundary, traceability, and evidence posture.

4.4 Method Boundary

Deterministic local CLI scan. No LLM, network, or runtime test execution is required.

Scope boundary: Runtime behavior, model output correctness, dynamic validation, wet-lab reproducibility, and clinical validation are outside the scope of this local CLI scan. This report assesses structural signals only.

Chapter 5 — Report Metadata

Field	Value
Schema Version	stem-ai-local-cli-result-v1.6
STEM BIO-AI Version	1.8.4
Generated (local date)	2026-06-24
Report Validity	180 days from audit date
Execution Mode	LOCAL_ANALYSIS
Repository	doctolib-lab/doctobert
Remote URL	https://github.com/doctolib-lab/doctobert
Branch	main
Commit (HEAD)	90a8bbe7260d9daaa64bfd0e8a167769da7646e
Files Scanned	134
Final Score / Tier	32 / 100 — T0 Rejected